

CITY UNIVERSITY OF HONG KONG

Course code & title : CS5285 Information Security for eCommerce

Session : Semester A 2020/21

Time allowed : Two hours

This paper has SEVEN pages (including this cover page).

1. This paper consists of 5 questions.
 2. Answer ALL FIVE questions.
 3. Total: 100 points
-

*This is a **open-book** examination.*

Candidates are allowed to use the following materials/aids:

Approved Calculators

Student's Own Copy of Notes/Lecture Slides

Materials/aids other than those stated above are not permitted. Candidates will be subject to disciplinary action if any unauthorized materials or aids are found on them.

CS Departmental Hotline (phone, whatsapp, wechat)

+852 6375 3293

Your answer sheet must include the signed academic honesty statement.

Academic Honesty

I pledge that the answers in this examination are my own and that I will not seek or obtain an unfair advantage in producing these answers. Specifically,

- ❖ I will not plagiarize (copy without citation) from any source;*
 - ❖ I will not communicate or attempt to communicate with any other person during the examination; neither will I give or attempt to give assistance to another student taking the examination; and*
 - ❖ I will use only approved devices (e.g., calculators) and/or approved device models.*
 - ❖ I understand that any act of academic dishonesty can lead to disciplinary action.*
- I pledge to follow the Rules on Academic Honesty and understand that violations may lead to severe penalties.*

Student ID:

Name:

Remark: Give concise reasons and show key steps in each problem. Keep your answers and reasons brief and right-to-the-point.

1. **Symmetric Encryption (23 marks):** For encrypting the i -th plaintext block P_i , $i = 1, 2, \dots$.

Mode 1: $C_i = P_i \oplus E(K, IV + i)$

Mode 2: $C_i = E(K, C_{i-1} \oplus P_i)$, where $C_0 = IV$.

Mode 3: $C_i = P_i \oplus E(K \oplus C_{i-1}, IV + i)$, where $C_0 = IV$.

- (a) (6 marks)

For all modes write down the equations for *decrypting* block P_1 and P_2 .

- (b) (5 marks)

Which mode is best if a 1-bit error occurs in the transmitted ciphertext. Briefly explain the error propagation for each mode.

- (c) (4 marks)

Suppose you have an encrypted file containing 100 ciphertext blocks ($C_1 - C_{100}$). The file stores only the ciphertext and you have none of the intermediate values you generated when you encrypted the file. You wish to decrypt block 51 (C_{51}). How many encrypt/decrypt block cipher operations do you need if the file was encrypted with *Mode 1*, and how many if it was encrypted with *Mode 3*?

- (d) (4 marks)

You have the same file setup as in 1.c. You now wish to modify block 51 you previously decrypted and write it back into the file. How many encrypt/decrypt block cipher operations do you need if the file was encrypted with *Mode 1*, and how many if it was encrypted with *Mode 3*?

- (e) (4 marks)

You are asked to implement encryption on a very low-resource payment card. There is not enough memory to implement a full block cipher such as AES or DES. The card can only implement a one-way function $f(k, m)$, where K is the secret symmetric key and m is a block of data. Which of the cipher modes given would you use? Explain your answer.

2. Public Key Cryptography and Message Integrity (22 marks):

(a) (3 marks)

We directly sign a message $m=99$ with RSA ($e=7$ $d=43$ $n=77$). Find another message that will give us the same signature. Explain why this is possible.

(b) (9 marks)

Answer the following questions related to the ElGamal algorithm. ElGamal with public values g and p works as follows:

Private key x is a value between 0 and $p-1$, and public key $y = g^x \bmod p$.

Ciphertext $C = (A, B)$ where $A = g^r \bmod p$ and $B = M \cdot y^r \bmod p$, with M being the message and r a random value between 0 and $p-1$.

C is decrypted by calculating $K = A^x \bmod p$ and $M = B \cdot K^{-1} \bmod p$.

i) If $g = 3$, $p = 19$, $y = 14$ and $C = (2, 14)$ what is M ? Show calculation. (6)

ii) Name and briefly explain the mathematical problem that ensures the security of ElGamal. What would an attacker gain if it could solve this problem? (3)

(c) (4 marks)

For RSA, if $n = 15$, list all the possible public/private key pairs (e, d) . Show calculation.

(d) (6 marks)

Assume h is a hash with output length 100 bits and MAC is a Message Authentication Code with output length 128 and key size 64. What is the average effort (number of hash or MAC computations) an attacker needs to do the following? Give your answer in 2^x format and briefly explain your answer.

i) Find any message x and message y so that $h(y)=h(x)$. (2)

ii) Once the attacker is given message z and $MAC(z)$, find any message x and message y so that $MAC(x)=MAC(y)$. (4)

3. Key Management and Authentication (23 marks):

(a) (4 marks)

i) Show how you would use asymmetric cryptographic between only two parties (no trusted 3rd party) to do *key transport*. (2)

ii) Show how you would use asymmetric cryptographic between only two parties (no trusted 3rd party) to do *key agreement*. (2)

(b) (6 marks)

Consider the mutual authentication protocol below. R_x is a nonce generated by x .

1. $A \rightarrow B : R_A$
2. $A \leftarrow B : (R_A + 1, R_B)_{A_{public}}$
3. $A \rightarrow B : R_B$

Discuss the security of this protocol. Your discussion must consider if the security objectives of the protocol is met and explain why or why not. If these are not met then fix the protocol (without adding any additional keys/cryptographic mechanism that Alice and Bob is not already able to perform, i.e. they can only do public key encryption and generate nonces)

(c) (3 marks)

For the protocol in 3.b, B needs the public key of A . How would B check if it has a valid public key for B ?

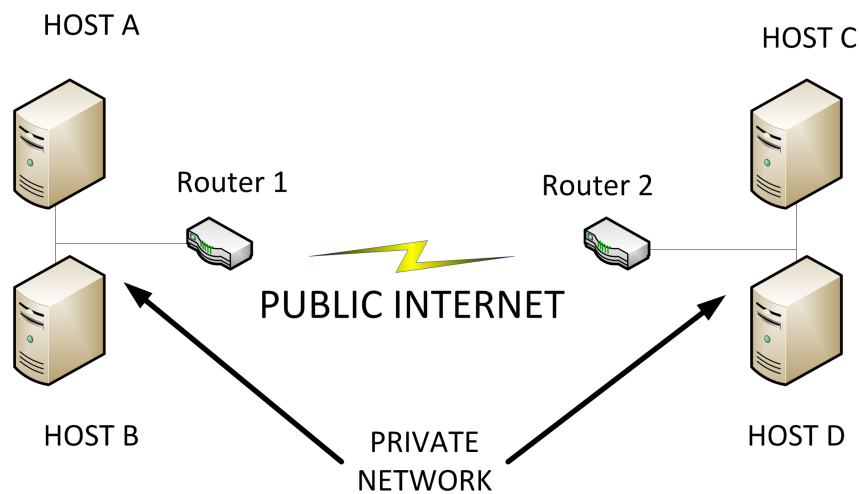
(d) (10 marks)

Design a protocol that will establish a new shared secret key K between Alice and Bob with the help of a third party. You can only use asymmetric cryptographic mechanisms and timestamps. At the end of the protocol the following conditions must be met:

- Mutual authentication of Alice and Bob; mutual authentication of TTP to Alice and unilateral authentication of TTP to Bob.
- Alice must have key control.
- No explicit key authentication required.

Your answer should be in the form of a protocol diagram between the parties, and you must clearly state your assumptions, explain all actions performed by both parties and define all your variables and notation.

4. Network Security (16 marks):



(a) (8 marks)

i) You wish to send a data packet between host A and host B. What IPSec mode and protocol would you choose if you need to authenticate the packet (including the IP header) but are not concerned with confidentiality? Explain how a basic packet with fields $|IPHeader|Data|$ would be modified as it is sent from A to B using your choices. (3)

ii) You wish to send a data packet between host A and host D. What IPSec mode and protocol would you choose if you wish to authenticate the packet (excluding the IP header) and provide data confidentiality? Explain how a basic packet with fields $|IPHeader|Data|$ would be modified as it is sent from A to D using your choices. (5)

(b) (4 marks)

You are opening up a new online business selling cupcakes. You would like to make sure that clients can verify that they are actually visiting your website, and you would also like to prevent attackers from seeing what the client is purchasing and payment details. What prominent security protocol would you use? What security services does this protocol provide to achieve the security you want your system to have.

(c) (4 marks)

- i) What is a DoS attack and which security services it is linked to. (2)
ii) Explain briefly the difference between DDoS and DoS attacks. (2)

5. Computer Security (16 marks):

(a) (3 marks)

Give your own example of two-factor authentication and explain what factors are used.

(b) (5 marks)

It is good practice not to store your user's personal information, including passwords, in plaintext. We therefore store the hash of the password instead. Assume that the user's password is a 8 characters (each character can be 0–9, a–z, A–Z).

i) If we have a password file with each entry $s, h(pwd, s)$ and s is a 8-bit number how many dictionary entries would an attacker need to cover all possible passwords? (2)

ii) If we have a password file with a secret salt – entry is only $h(pwd, s)$ – and s is a 8-bit number how many dictionary entries would an attacker need to cover all possible passwords? How much computation effort would we need to verify a signature? (3)

(c) (3 marks)

You are responsible for making sure a bank provides a secure online website for their customers. Your customers keep getting fooled by phishing attacks and attackers are using their credentials to log in and transfer money to the attacker's account.

How could you change your password log in procedure to be resistant to phishing?

Why does your idea prevent phishing?

(d) (2 marks)

Look at the segment of pseudo-code below and explain what kind of malware is likely to contain such code.

```
Scan local network;
For each host found do:
{
    Open connection;
    Send copy of malware;}
```

(e) (3 marks)

Currently there is a need for a system ensuring that people under quarantine for COVID-19 remain inside their home. Assume there is a system that issues each user with a wrist band, which has a printed QR code on it. The user must scan this QR code with a mobile every hour and the mobile then uploads the user's ID and current location (from the mobile) to the central system. A person makes a copy of their QR code, leaves their phone at home and gets someone to take photo of QR code copy every hour. Considering what you have learned about user authentication – what security issue does this attack expose? How would one fix this?

The End